

DUOTHAN 6.0 - PHASE 01 - RECON

FINIX - Financial Infrastructure NeXt

Resilient Inclusive Banking Fabric

Project Blueprint Submission

IEEE Student Branch of NSBM

Submitted by

Team Rexosphere

Sangeeth Kariyapperuma

Kalana Liyanage

Ifaz Ikram

Suhas Dissanayake

Date: July 22, 2026

Contact: info@ieeensbm.org | duothan@ieeensbm.org

Table of Contents

1. Problem Identification
2. Proposed Solution
3. System Architecture Diagram
4. Wireframes Design
5. Functional Requirements
6. Non-Functional Requirements
7. Technology Stack Selection

01 Problem Identification

Scenario Context: Year 2065 Super Malware Agent has destroyed monolithic banking cores. Core banking, ATMs, digital payments, loans are offline. Customer DB backups are safe but Master Key is locked behind security layers. Need to rebuild from ground up.

1.1 Root Cause Analysis

- Monolithic Architecture: Single shared database, single network zone. One compromise = total system failure. No blast radius containment.
- Missing Zero Trust: Implicit trust inside network. No mTLS between services, no continuous verification of identity.
- Single Point of Failure - Master Key: Master key stored centrally, no Shamir Secret Sharing or MPC.
- No Offline Fallback: 100% dependent on internet. USSD, NFC, delay-tolerant queuing missing. Rural and feature phone users excluded.
- No Immutable Audit: Logs mutable, so post-attack integrity cannot be proven.

1.2 Affected Users and Impact

- Rural Farmers & Daily Wage Workers: Cannot receive payments, forced to cash economy. Financial inclusion reversed.
- SMEs in Moratuwa & Urban Areas: Cannot process QR/ POS. Revenue loss 70%+ during outage.
- Elderly & Differently-Abled: Complex apps, no voice in Sinhala/Tamil, no low-data mode.
- Regulators & Central Bank: Lost operational control, trust deficit from citizens.
- Banks: Reputational damage, liquidity crisis, no disaster recovery with low RTO/RPO.

1.3 Problem Statement

How might we design a secure, scalable, inclusive financial platform that restores daily banking, ensures no single point of failure can bring down the entire system again, supports offline transactions for the unbanked, and recovers Master Key via distributed trust with post-quantum security?

Success is measured by: Trust restoration, economic recovery, and resilience against future Super Malware attacks.

02 Proposed Solution

Our solution is FINIX - Financial Infrastructure NeXt, a banking mesh not a banking app.

2.1 Core Philosophy

Rebuild as independent services with zero implicit trust. Inspired by SecureBank Financially-Aware Zero Trust architecture which integrates Financial Zero Trust, Adaptive Identity Scoring, Contextual Micro-Segmentation, and Impact-Driven Automation.

2.2 Key Innovations to Beat the Malware

- 1. Zero-Trust Service Mesh: Istio provides mTLS, policy-based access control, traffic monitoring, offering zero-trust across service boundaries. Every service call is authenticated and authorized.
- 2. Vault Service with Shamir Secret Sharing: Master Key split into 5 shards (Central Bank, Govt DR, IEEE Vault, 2 Cloud HSMs). Threshold 3 of 5 required. Uses information-theoretic security. Reconstruction only inside confidential computing enclaves (AWS Nitro Enclaves / Intel SGX), never in plaintext. Shares are extensible and dynamic.
- 3. Post-Quantum Cryptography: CRYSTALS-Kyber for key exchange (highest agility) and CRYSTALS-Dilithium for signatures. Quantum-resilient for 2065+ threats.
- 4. Offline-First Inclusion - Aligned to BIS Project Polaris: Configurable offline duration, transaction limits, reconciliation windows. Stack: USSD gateway (*334#) for feature phones without internet, on-device SQLite queue, NFC P2P, Secure Element double-spend prevention. When online, Kafka syncs events.
- 5. Immutable Audit Anchor: Transactions in PostgreSQL but SHA-256 hash anchored to Hyperledger Fabric every 60 seconds using BLS signatures. Provides verifiable integrity without using blockchain for payments.
- 6. AI Shield: Federated anomaly detection isolates compromised service. Circuit breaker + automatic microservice quarantine.

2.3 User Journey

User dials USSD or opens low-data app (<50kb). Adaptive identity scores device + biometric. Transaction orchestrator uses Saga pattern. Ledger commits, event emitted to Kafka, hash anchored. If offline, stored locally and synced. Notification via SMS / voice in Sinhala/Tamil/English.

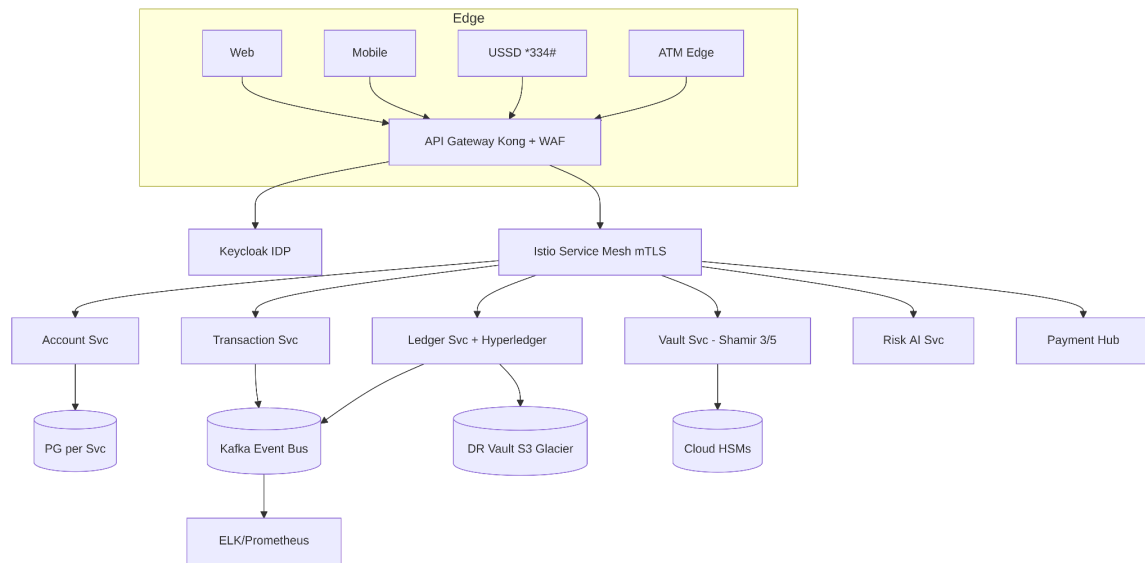
2.4 Value Proposition

- For Citizens: Banking that works even without internet, in their language.
- For SMEs: Instant QR, micro-loans for recovery, transparent ledger.
- For Regulators: No single point of failure, auditable, RTO 15 min RPO 1 min.

03 System Architecture Diagram

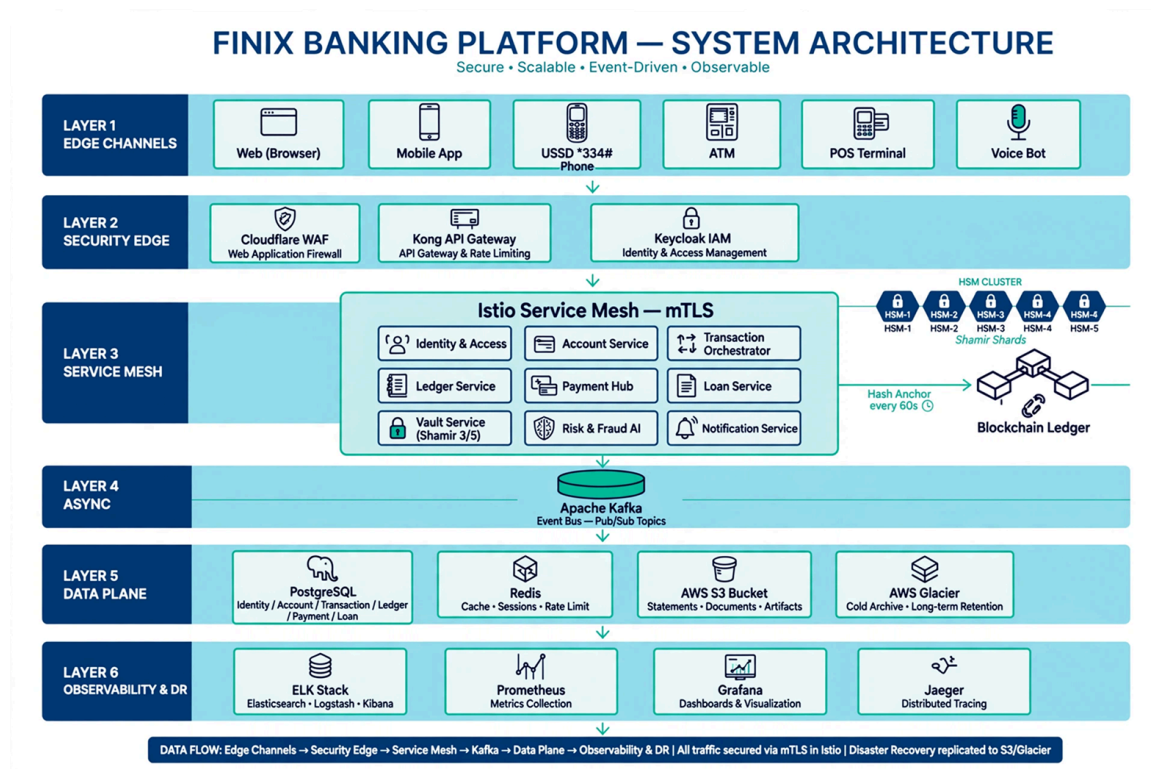
3.1 Layered Architecture Overview (6 Layers)

- Layer 1 Edge Channels: Web (Next.js), Mobile (React Native), USSD Gateway, ATM Edge Agent, POS Terminals, Voice Bot.
- Layer 2 Security Edge: Cloudflare WAF -> Kong API Gateway (auth, rate limiting, logging) -> Keycloak IAM (OAuth2 + MFA + WebAuthn).
- Layer 3 Service Mesh (Zero Trust): Istio service mesh enforcing mTLS, RBAC per service, continuous verification. Identity-first security.
- Layer 4 Business Microservices (Database per Service):
 - Identity & Access Service (PostgreSQL + Redis) - Decentralized ID, MFA*
 - Account Service (PostgreSQL) - Accounts, balances*
 - Transaction Orchestrator (Saga Orchestration) - 2PC replaced with Saga*
 - Ledger Service (Immutable PostgreSQL) + Hyperledger Anchor*
 - Payment Hub (lankaPay, Visa, CBDC gateway)*
 - Loan Service*
 - Vault Service - Master Key with Shamir 3-of-5*
 - Risk & Fraud AI Service (Python + Kafka Streams)*
 - Notification Service*
 - Compliance Service*
- Layer 5 Async & Data Plane: Kafka event bus for eventual consistency, ELK for logs, Redis cache, S3/Glacier backups, AES-256-GCM + Kyber encryption at rest.
- Layer 6 Observability & DR: Prometheus, Grafana, Jaeger (OpenTelemetry), Active-Active Multi-Region Colombo primary + Singapore DR, automated failover.



3.2 Communication & Data Flow

- Synchronous: REST/gRPC via API Gateway -> Service Mesh -> Service. For real-time transfers.
- Asynchronous: Kafka topics: transaction.initiated, transaction.committed, offline.sync, audit.anchor. Handles offline reconciliation and prevents total failure.
- Master Key Flow: User request to unlock -> Vault requests 3 shards -> shards loaded into Nitro Enclave -> reconstruction inside enclave -> key used to decrypt banking network config -> key destroyed from memory.



(AI Generated Image: with 6 Layers)

04 Wireframes Design

Figma Link:

<https://www.figma.com/design/YORai8C8oL2fnCo7twMB7w/Duothan-6.0-Proposal---Rexospher-e?node-id=0-1&t=7TMBqVeG1g4PN7WI-1>

We did not copy and paste screenshots in here, You can view the design using the above links.

05 Functional Requirements

5.1 Functional Requirements Table

ID	Category	Requirement	Priority
FR-01	Identity	Register with NIC + biometric, MFA login, adaptive trust	Must

		scoring, recovery via shards	
FR-02	Account	Create/view accounts, low-data mode <50kb, trilingual UI	Must
FR-03	Transaction	Internal/inter-bank transfer, QR/NFC offline with limits, Saga pattern consistency	Must
FR-04	Ledger	Immutable ledger, hash anchor to Hyperledger every 60s, downloadable audit	Must
FR-05	Payments	USDD *334# for balance/transfer, ATM/POS integration, bill pay	Must
FR-06	Lending	SME micro-loan request, AI credit scoring, repayment tracking	Should
FR-07	Vault	Split Master Key 5 shards, reconstruct with threshold 3/5 inside enclave only	Must
FR-08	Risk	Real-time fraud detection, auto-isolate compromised service, AML checks	Must
FR-09	Notifications	SMS, push, voice call notifications, offline sync alerts	Should
FR-10	Admin	Service health dashboard, DR failover trigger, audit log viewer	Must

06 Non-Functional Requirements

6.1 Security NFRs

- Zero Trust per NIST SP 800-207: Never trust, always verify, continuous auth, micro-segmentation, mTLS everywhere, JWT expiry 5 min.

- Post-Quantum: Kyber-768 for KEM, Dilithium3 for signatures, hybrid classical+PQC during transition.
- Vault: Shamir Secret Sharing information-theoretic security, no single custodian, enclave-only reconstruction, verifiable secret sharing to prevent fake shares.
- Data: AES-256-GCM at rest, TLS 1.3 + Kyber in transit, Hashicorp Vault for secrets, PCI-DSS v4, ISO 27001.

6.2 Reliability & DR

- Uptime 99.99%, circuit breaker (Resilience4j), retry with exponential backoff, bulkhead pattern.
- RTO 15 minutes, RPO 1 minute, Active-Active multi-region, hourly snapshots to S3 Glacier, chaos engineering tests monthly.

6.3 Performance & Scalability

- API p95 <200ms, offline QR gen <2s, supports 10k TPS via Kafka partitioning and Kubernetes HPA.
- Independent scaling: Payment Hub scales separately from Account service.

6.4 Inclusivity & Compliance

- Offline: Works without internet via USSD (real-time session messaging) and on-device queue.
- Accessibility: WCAG 2.2 AA, Sinhala/Tamil/English, voice navigation, low-data mode.
- Compliance: Audit logs immutable, retention 7 years, GDPR-like data minimization, Travel Rule for AML/CFT.

07 Technology Stack Selection

7.1 Frontend

- Web: Next.js 15 + TypeScript, TailwindCSS - SSR for fast first paint, low bundle.
- Mobile: React Native + Expo - single codebase, offline SQLite support.
- State: Zustand, React Query for caching.

7.2 Backend

- Core Banking: Spring Boot 3 + Kotlin - mature, strong typing, great for banking domain.
- Payment Hub: Go (Golang) - high concurrency for payments.
- Notification/AI Gateway: Node.js + Python FastAPI for AI service.
- API Gateway: Kong - rate limiting, logging, auth plugin.
- IAM: Keycloak - OAuth2, OIDC, MFA, WebAuthn.
- Service Mesh: Istio - mTLS, RBAC, observability.

7.3 Data & Messaging

- PostgreSQL per service - ACID for money, TimescaleDB extension for ledger time series.

- Redis - session, rate limit, cache.
- Kafka - event streaming, exactly-once semantics, DLQ for failures.
- S3 + Glacier - document store + DR backups.
- Hyperledger Fabric - permissioned blockchain for audit anchor only.

7.4 Security Stack

- HashiCorp Vault + AWS KMS + Nitro Enclaves / Intel SGX.
- Kyber/Dilithium libs (liboqs), BLS signatures for audit.
- WAF (Cloudflare), ELK + Prometheus + Jaeger for SOC.

7.5 Cloud & DevOps

- AWS EKS (Colombo Region) + GCP GKE (Singapore DR), Docker, Terraform IaC, GitHub Actions CI/CD, SonarQube + OWASP ZAP scanning.

7.6 Justification to Win

- Polyglot microservices prevents total takedown - if one language runtime is exploited, others survive.
- Kafka + Saga ensures resilience when DB down - aligns with independent services requirement.
- Shamir + Enclave directly solves Master Key hidden behind security layers story.
- Offline USSD + BIS Polaris shows inclusion innovation beyond typical banking app.

Reference:

- NIST SP 800-207 Zero Trust, BIS Project Polaris Offline CBDC Handbook Oct 2023, SecureBank Zero Trust Paper 2025, Shamir Secret Sharing 1979, NIST PQC Kyber/Dilithium.